

ИМИТАЦИЯ ФУНКЦИОНИРОВАНИЯ ЦЕНТРА ИНФОРМАЦИОННОЙ БЕЗОПАСНОСТИ В УСЛОВИЯХ РЕАЛИЗАЦИИ КИБЕРАТАК

В.А. Минаев, Е.С. Поликарпов

Статья посвящена проблеме моделирования работы центра информационной безопасности предприятия (ЦИПБ) в условиях реализации кибератак. Имитационная модель позволяет решать широкий спектр задач, в частности, задач управления временем обработки сообщений об инцидентах безопасности, оптимизации ресурсного обеспечения информационной безопасности предприятия, ее прогнозирования. Показано, что для решения указанных хорошо применимы методы дискретно-событийного моделирования. Дискретно-событийная модель ЦИБП отражает современные тренды в области технологического обеспечения информационной безопасности предприятий и организаций; учитывает наиболее существенные факторы, влияющих на характеристики информационной безопасности предприятий; обеспечивает баланс между требуемой точностью результатов моделирования и сложностью модели; отличается универсальностью, адаптивностью для решения многих задач управления информационной безопасностью, гибкостью разработки моделей в современной среде имитационного моделирования. В качестве среды имитационного моделирования выбрано программное обеспечение отечественного производства Anylogic, позволившее проигрывать различные сценарии кибератак на ЦИБП, помогающее качественно интерпретировать результатов реализации моделей, провести различные виды имитационных экспериментов, в том числе – по вариации параметров моделей, анализу их чувствительности, оптимизации ресурсного обеспечения информационной защиты. Сделан вывод, что дальнейшим развитием исследования ЦИБП предприятий является уточнение и детализация модели, структуры ее блоков и содержания сообщений о компьютерных инцидентах.

Ключевые слова: кибератака, предприятие, информационная безопасность, дискретно-событийное моделирование, SIEM-система, SOC-центр, имитация.

Введение

Развитие информационных технологий повсеместно влечет за собой совершенствование информационных систем и сетей. Сегодня даже небольшие организации имеют свои информационные системы, актуальной проблемой для которых является защита от кибератак, с каждым годом возрастающих в количественном и видоизменяющихся в качественном отношении.

Согласно [1] количество и уровень опасности киберугроз постоянно возрастает. При этом увеличивается доля уникальных киберинцидентов, связанных не только с целенаправленными атаками против отдельных организаций и структур, но и целых отраслей производства.

Чтобы защитить информационные системы от воздействия компьютерных атак, применяются новые подходы. Одним из них является создание и развитие базирующихся

на SIEM-системах [2] Центров информационной безопасности предприятий (ЦИБП).

Настоящая статья посвящена разработке и исследованию имитационной модели SIEM-системы, обеспечивающей кибербезопасность современного предприятия, и обсуждению полученных результатов, направленных на совершенствование структуры и алгоритмов функционирования названной системы.

Общая направленность процесса моделирования связана с анализом, оценкой и прогнозированием последствий компьютерных атак различного масштабного уровня на функционирование современных предприятий и на выработку эффективных решений по управлению противодействием компьютерным атакам. Полученные результаты могут быть использованы при разработке современных центров информационной безопасности предприятий.

Центры информационной безопасности предприятий

ЦИБП - *распределенная система, базирующаяся на использовании методов оценки рисков информационной безопасности для защиты активов организации.*

Задача ЦИБП – защита информационных активов организации, минимизация ущерба и ликвидация последствий от компьютерных атак.

Основными компонентами ЦИБП являются:

ИТ-инфраструктура предприятия;
средства защиты информации;
система сбора событий информационной безопасности и управления событиями – Security Information and Event Management (SIEM);

центр мониторинга инцидентов информационной безопасности - Security Operations Center (SOC).

Система сбора событий информационной безопасности и управления событиями – это программный комплекс, осуществляющий анализ в реальном времени событий безопасности, исходящих от сетевых устройств и приложений. Система реализует следующие основные функции [2]:

сбор данных и нормализация – обеспечение сбора данных (как событий ИБ, так и системных событий) от разнообразных источников;

корреляция данных – сопоставление и поиск по атрибутам, группирование и индексирование данных по определенным признакам с целью формирования на выходе списка взаимосвязанных событий;

оповещение – проверка списка взаимосвязанных событий с целью выявления инцидентов ИБ и выполнения оповещений по инцидентам. Возможно автоматизированное уведомление по разработанному корреляционным правилам;

визуализация – отображение информации по текущим событиям и инцидентам в виде графиков различных типов, таблиц, списков и других форматов, облегчающих общее восприятие и мониторинг состояния ИБ;

хранение данных – хранение информации как о “сырых” событиях (до их

распознавания), так и о нормализованных событиях (распознанные события), необходимой для ретроспективного анализа, расследований инцидентов, экспертиз;

поиск и анализ – контекстный поиск в рамках расследований инцидентов и экспертиз. Отметим, что поиск в массивах “сырых” и нормализованных событий может существенно отличаться.

создание отчетов – периодическое документальное информирование службой ИБ о текущих событиях, инцидентах, трендах.

Центр мониторинга инцидентов информационной безопасности реагирует на критические инциденты информационной безопасности (ИБ), позволяя предотвращать атаки и осуществлять полный мониторинг сетевых пакетов и потоков, активности операционной системы, контента, поведения пользователей. Операторы Центра обрабатывают поступившие в центр инциденты ИБ и принимают решение по каждому из них.

Следует отметить, что Центры мониторинга могут быть организованы, по крайней мере, в виде пяти различных вариантов:

1. *Команда безопасности*, мобилизуемая при обнаружении инцидента для устранения его возможных последствий.

2. *Внутренний распределенный* – вариант, когда основная деятельность специалистов Центра не связана с его деятельностью.

3. *Внутренний централизованный* – вариант, когда штат специалистов по ИБ организует защиту и реагирует на инциденты в режиме реального времени.

4. *Внутренний комбинированный* – вариант, при котором происходит сочетание второго и третьего из указанных ранее вариантов.

5. *Координационный* – вариант, когда Центр функционирует как консалтинговая система, взаимосвязанная с другими Центрами, при этом собираются и применяются лучшие практики разрешения киберугроз.

Родоначальниками применения ЦИБП стали США [3], реализовав основные компоненты Центра в виде схемы, представленной на рис. 1.

В России за последнее время многое изменилось в работе ЦИБП. Приняты новые федеральные законы, постановления правительства. Разработаны и введены в действие нормативные документы ФСБ и

ФСТЭК России в области обеспечения информационной безопасности предприятий [4-15].

Российские компании осознали необходимость мониторинга инцидентов информационной безопасности. Многие из них начали создавать свои SOC или, исходя из экономии ресурсов, подключаться к SOC других компаний на договорной основе.

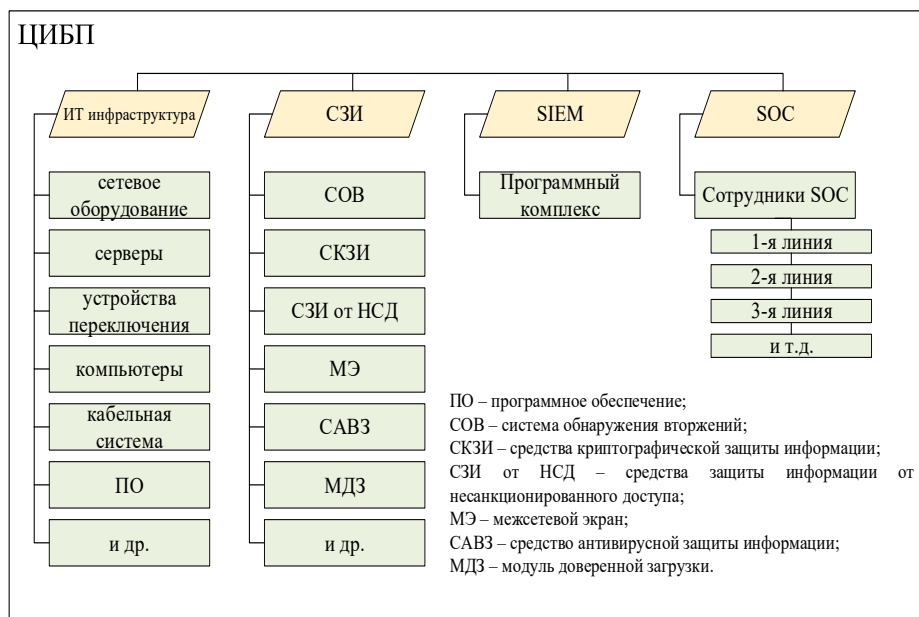


Рис. 1. Компоненты Центра информационной безопасности предприятия

Для критической информационной инфраструктуры (КИИ) в соответствии с [16] создана – государственная система обнаружения, предупреждения и ликвидации последствий компьютерных атак (ГОССОПКА), направленных на информационные ресурсы Российской Федерации. Цель системы — объединить усилия по предотвращению и противодействию кибератакам на критически важные информационные инфраструктуры. Для этого создан Национальный координационный центр по компьютерным инцидентам, который организует сбор и обмен информацией об инцидентах между субъектами КИИ, координирует мероприятия по реагированию, дает методические рекомендации по предупреждению компьютерных атак.

Имитационное моделирование систем информационной безопасности

Рассмотрим некоторые программно-математические комплексы имитационного моделирования [17], указав принципы и области применения.

1. *AGNES* – система имитационного моделирования больших дискретных систем является кроссплатформенной со следующими областями применения: локальные компьютерные сети, беспроводные сенсорные сети, вычисления на суперЭВМ.

2. *AweSim* – система имитационного моделирования для сети с дискретной или непрерывной интерпретацией. Возможные области применения: бизнес, промышленность, здравоохранение, военное дело. Система включает построение интерактивной модели, анимацию, интерактивное представление результатов имитации в текстовом и графическом видах, реализацию различных сценариев.

3. Система *ExtendSim* – позволяет моделировать непрерывные, дискретно-событийные, основанные на агентах, линейные, нелинейные и процессы смешанного типа.

4. Среда моделирования *Enterprise Dynamics* – программная платформа для бизнес-моделирования, позволяющая анализировать и оптимизировать текущее и будущее поведение системы или инфраструктуры, обнаруживать узкие места, оценивать различное распределение персонала, прогнозировать развитие событий.

5. Для создания и исследования модели функционирования центра информационной безопасности современного предприятия авторы использовали систему моделирования *AnyLogic*, поддерживающую три подхода к созданию имитационных моделей: процессно-ориентированный (дискретно-событийный), системно-динамический и агентный, а также любую их комбинацию [17].

Графический интерфейс *AnyLogic*, инструменты и библиотеки позволяют быстро создавать модели для широкого спектра задач – от моделирования производства, логистики, бизнес-процессов до стратегических моделей развития компаний и рынков, а также процессов обеспечения информационной безопасности, включая информационно-технические и информационно-психологические факторы воздействия на нее [18-20].

Среда моделирования *AnyLogic* – инструмент имитационного моделирования, с которым работают пользователи в шести десятках стран мира [17]. Программный продукт предназначен для проектирования и оптимизации бизнес-процессов или любых сложных систем, таких как производственный цех, аэропорт, госпиталь и т.д.

Инструмент поддерживает все методы бизнес-моделирования – системную динамику, дискретно-событийное (процессное) и агентное моделирование. Основной упор в разработке продукта сделан на его гибкость и простоту применения при создании моделей.

Графическая среда моделирования *AnyLogic* включает в себя следующие элементы:

диаграмма потоков и накопителей применяется при разработке моделей, используя метод системной динамики;

карты состояний в основном используются в агентных моделях для определения поведения агентов. Но также часто используется в дискретно-событийном моделировании, например, для воспроизведения машинных сбоев;

блок-схемы используются для построения алгоритмов. Применяется в дискретно-событийном моделировании (маршрутизация звонков) и агентном моделировании (для отображения логики решений агента);

процессные диаграммы – основная конструкция, используемая для определения процессов в дискретно-событийном моделировании.

Среда моделирования *AnyLogic* поддерживает проектирование, разработку, документирование модели, выполнение компьютерных экспериментов с моделью, включая различные виды анализа — от анализа чувствительности до оптимизации параметров модели.

На рис. 2 представлена обобщенная модель Центра информационной безопасности предприятия.

Для сбора событий из всех источников используется *блок сбора и нормализации сообщений*, передаваемых в различном виде. Для определенных событий может производиться автоматическое определение географического положения его источника по IP-адресу [21].

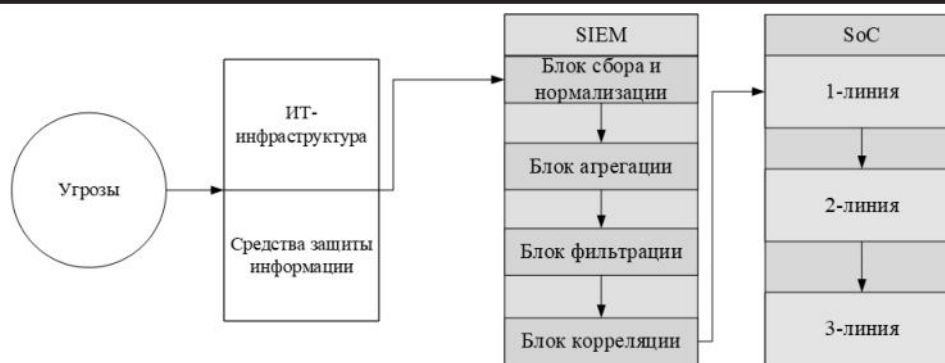


Рис. 2. Обобщенная модель ЦИБП

После сбора нормализованные события поступают в *блок агрегации*, где происходит объединение однотипных из них, что позволяет сузить поле вариантов реагирования.

Далее события поступают в *блок фильтрации*, где разделяются на несущие полезную информацию и не несущие таковую.

После этого сообщения о событиях поступают в *блок корреляции*, предназначенный для обнаружения, идентификации и регистрации инцидентов. Корреляция осуществляется в соответствии с ее директивами, включающими цепочки правил. Директивы могут быть как предустановленными в систему, так и пользовательскими.

В конечном итоге, после обработки в SIEM-системе, сообщения о событиях, относительно которых ею не принято автоматизированного решения, является ли последние деструктивными компьютерными инцидентами либо не относятся к таковым, направляются в SOC, где происходит их обработка экспертами, затрачивающими на это достаточно большое время, измеряемое часами и даже днями.

Для эффективной работы SIEM-системы необходимо, чтобы интенсивность сообщений о событиях на каждом этапе не превышала производительности их обработки в каждом блоке. Произведем некоторые расчеты и оценки.

Согласно [22, 23] один источник в среднем генерирует 3 события в секунду. В рабочее время генерируется больше событий, ночью и в выходные дни события практически не генерируются. После всех этапов обработки в блоках SIEM с подозрением на инцидент остается 0,00015%

от всех входящих событий, которые направляются аналитикам SOC для детального анализа. Согласно [23], время на обработку одного события и выявление риска (после обработки события во всех блоках SIEM) составляет не более 10 секунд.

Исходя из такой оценки, имеем соотношение:

$$t_1 + t_2 + t_3 + t_4 \leq 10 \quad (1)$$

где t_1 – время, необходимое на сбор и нормализацию событий и зависящее от производительности SIEM-системы, относящейся к одному из трех типов – низконагруженные, средненагруженные и высоконагруженные [23], которые используют разную аппаратную реализацию, определяющую скорость обработки сообщений;

t_2 – период времени, требующийся для агрегации событий;

t_3 – период времени для фильтрации событий, определяемый производительностью SIEM-системы и количеством правил фильтрации.

t_4 – период времени корреляции, зависящий от количества правил корреляции.

Общее количество сообщений о событиях, приходящих в SIEM-систему, в зависимости от времени суток t определяется соотношением

$$N(t) = \sum_i^I X_i \cdot n_i(t), \quad (2)$$

где X_i – i -е устройство сбора событий; n_i – интенсивность появления сообщений от i -го устройства; $i=1, \dots, I$. Величина интенсивности зависит от времени суток t .

Пусть суммарное количество событий, проходящих через блок сбора и нормализации в определенный период времени, описывается формулами:

$$N_1 = (1 - k_a) \cdot N \quad (3)$$

$$N_2 = k_a \cdot k_p \cdot N \quad (4)$$

где N_1 – количество неагрегированных событий, N_2 – количество агрегированных событий, k_a – коэффициент агрегации (доля однотипных событий), зависящий от количества типов событий, k_p – коэффициент сжатия при агрегировании событий.

Определим количество неинформативных и информативных событий как:

$$N_3 = (1 - k_f) \cdot (N_1 + N_2) \quad (5)$$

$$N_4 = k_f \cdot (N_1 + N_2) \quad (6)$$

где N_3 – количество неинформативных событий, N_4 – количество информативных событий, k_f – коэффициент фильтрации.

Количество событий с подозрением на инцидент определим как:

$$N_5 = k_d \cdot N_4 \quad (7)$$

где k_d – коэффициент корреляции.

Как показано в [22, 23]:

$$N_5 = 0,0000015 \cdot N \quad (8)$$

Из (3)-(8) получим выражение для взаимосвязи коэффициентов, необходимое при имитации различных режимов работы SIEM-систем:

$$k_d \cdot k_f [k_a \cdot (k_p - 1) + 1] = 0,0000015 \quad (9)$$

где k_a, k_f, k_d, k_p изменяются в пределах от 0 до 1.

При этом необходимо учитывать, что, исходя из зависимости (2), параметры в соотношении (9) могут быть представленными кусочно-постоянными величинами в течение определенных временных периодов. Такое представление, в частности, дает возможность учесть то обстоятельство, что в рабочее время формируется гораздо больше событий, чем в нерабочее, так как рабочие станции пользователей и средства защиты на них в этот период, как правило, неактивны.

Экспериментальная часть

Для исследования поведения SIEM-системы в условиях существенно различающихся типов компьютерных атак авторами разработана её дискретно-событийная модель, на которой проведено три имитационных эксперимента.

Эксперимент 1

В качестве экспериментального взято предприятие среднего размера (до 250 человек), эксплуатирующее:

серверы – 10 единиц;

сетевое оборудование – 10 единиц;

компьютеры – 100 единиц;

средства защиты информации – 100 единиц;

Web-сервисы – 10 единиц.

Проанализируем нагрузку на ЦИБП в рабочие и нерабочие часы.

Эксперимент 2

Рассмотрено предприятие из эксперимента 1 с тем же оборудованием, но на 30 компьютерах произведено обновление программного обеспечения. Предположено, что количество сообщений о событиях с них возрастет в 3 раза. Сравним показатели нагрузки на ЦИБП в рабочие часы в экспериментах 1 и 2.

Эксперимент 3

Рассмотрим то же предприятие, но с количеством оборудования, большим в 2 раза, чем в эксперименте 1. Сравним показатели нагрузки на ЦИБП в экспериментах 3 и 1.

Результаты эксперимента 1

На рис. 3 представлена средняя очередь событий в блоках сбора и нормализации, фильтрации и корреляции SIEM-системы в рабочее время. Как видно из рис. 3, при данной нагрузке очередей во всех рассмотренных блоках нет.

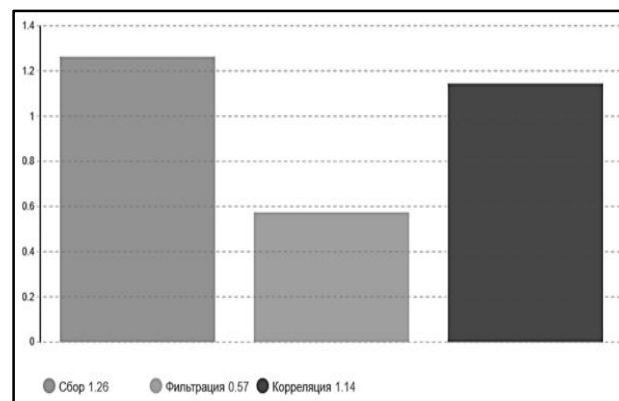


Рис. 3. Загрузка блоков SIEM-системы в рабочее время

Средняя очередь в блоке сбора и нормализации событий составляет 1,26 события. В блоке агрегации – 0,57, в блоке корреляции – 1,14 событий.

На рис. 4 представлена максимальная очередь событий в блоках сбора и нормализации, фильтрации и корреляции SIEM-системы.

Максимальная очередь в блоке сбора и нормализации составляет 30 событий, что гораздо меньше, чем его вместимость. Максимальная очередь в блоке фильтрации и блоке корреляции составляет 19 событий, что также меньше, чем их вместимость.

На рис. 5 представлена статистика по блоку агрегации, в котором события специально накапливались в течение 0,5 секунд.

Количество событий, которые успевает накапливать блок агрегации за 0,5 секунды для обработки, в среднем составляет 1149 события. Максимум событий, которые блок агрегации успевает накапливать – 1314.

Загрузка линий SOC представлена на рис. 6.

Из рис. 6 видно, что третья линия SOC не задействуется совсем. Средний коэффициент использования первой линии составляет 0,16, второй линии – 0,38. Из этого можно сделать вывод, что SOC со своими задачами справляется успешно.

Максимальная загрузка линий SOC в рабочее время представлена на рис. 7.

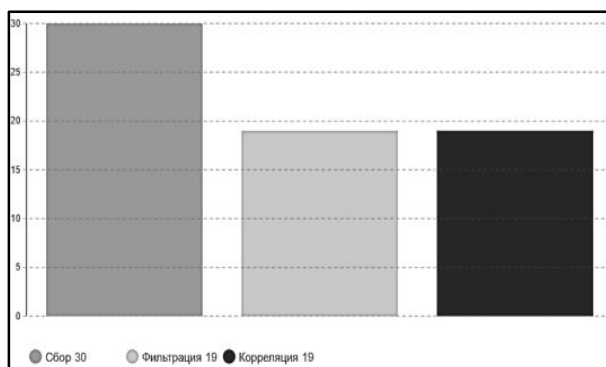


Рис. 4. Максимальная очередь в блоках SIEM-системы в рабочее время

Максимальный коэффициент использования первой линии SOC составляет 0,4; второй – 0,8.

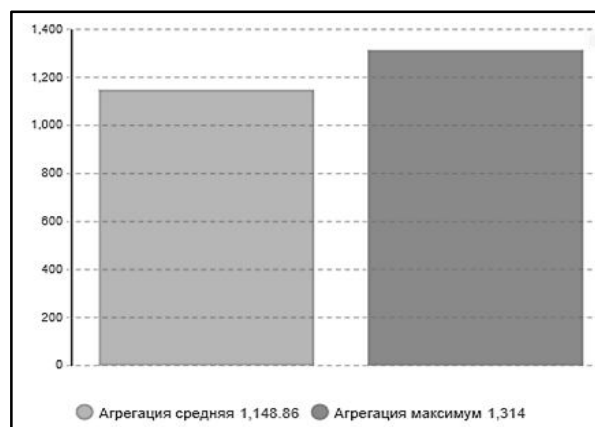


Рис. 5. Загрузка блока агрегации в рабочее время

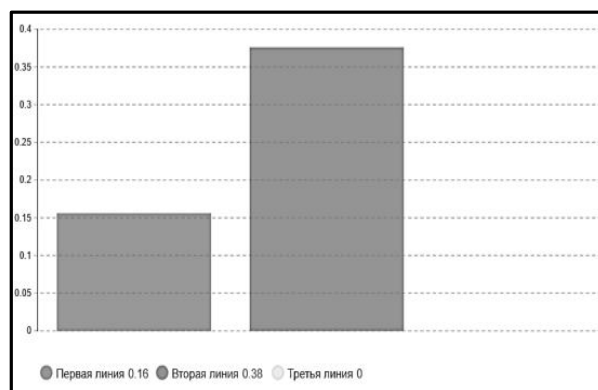


Рис. 6. Загрузка линий SOC в рабочее время

Проведенные эксперименты показали, что до стадии обработки аналитиками третьей линией SOC-центра доходит только 1 случай из 20 с временем обработки 1 сутки. С учетом того, что аналитик третьей линии SOC занимается разбором инцидента в среднем 5 рабочих дней, то и третья линия SOC также работает штатно.

Из представленных на рис. 3-7 данных можно сделать вывод, что все составляющие центра информационной безопасности предприятия работают штатно и успешно выполняют свои функции.

Таким образом, моделирование устойчивого режима обработки событий в блоках SIEM-системы.

Как следует из рис. 8, среднее время обработки событий в данном блоке составляет 0,00033 секунды. За счет простоя в очереди оно доходит до 0,01 секунды.

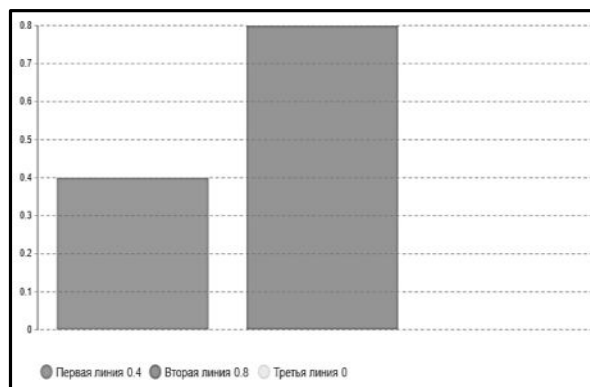


Рис. 7. Максимальная загрузка линий SOC в рабочее время

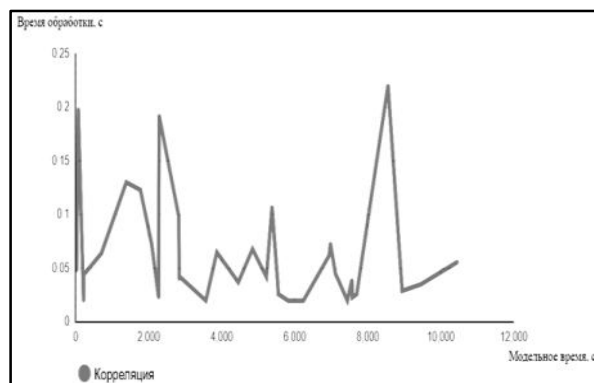


Рис. 9. Время обработки событий в блоке корреляции

На рис. 8 представлено изменение время обработки событий в блоке их сбора и нормализации.

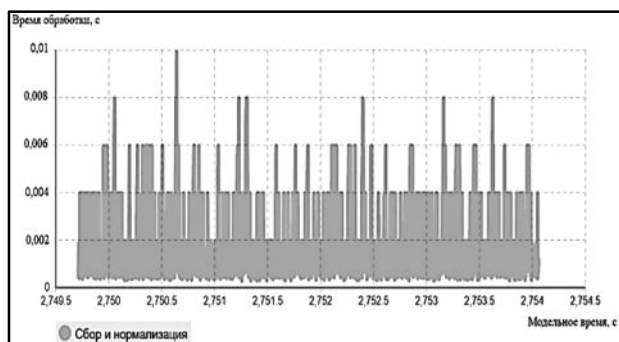


Рис. 8. Динамика обработки событий в блоке сбора и нормализации

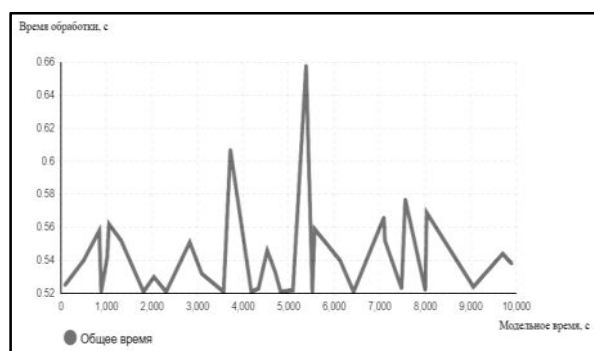


Рис. 10. Общее время обработки событий в SIEM-системе

В блоке фильтрации также наблюдается существенная нестационарность. Хотя изначально оно задано равным 0,0004 секунды, за счет образования очереди происходит его заметное увеличение.

На рис. 9 приведено время обработки событий в блоке корреляции.

Как и в предыдущих блоках, реальное время обработки событий существенно выше, чем изначально заданное.

Будучи обусловленным различными факторами, определяющими время обработки сообщений о событиях в каждом блоке, общее время обработки в SIEM-системе также существенно нестационарно и показано на рис. 10.

Как видно из рис. 10, общее время обработки события не превышает 0,66 секунды.

Рассмотрение функционирования SIEM-системы с помощью имитационной модели в нерабочее время приводит к очевидным результатам: все события, которые произошли в рабочее время, обработаны; средняя и максимальная очереди событий в блоках сбора и нормализации, фильтрации, корреляции существенно снизились.

Количество событий, которые успевает накапливать блок агрегации за 0,5 секунды для обработки, в среднем составляет 51 событие; максимум событий, которые блок агрегации успевает накапливать, составляет 86.

Количество событий для обработки настолько мало, что они практически не доходят до SOC-центра. Его вторая и третья линии не используются совсем.

В целом нагрузка на центр информационной безопасности в нерабочее время снижается в десятки раз.

Результаты эксперимента 2

Выделим 30 из имеющихся компьютеров предприятия в отдельную подгруппу и зададим для них свое расписание активности в рабочее время.

Воздействие указанных изменений на загруженность линий SOC, как показал эксперимент, минимально, поэтому будем рассматривать только SIEM-систему.

Средняя длина очереди событий в блоках сбора и нормализации, фильтрации, корреляции SIEM-системы, по сравнению с экспериментом 1, возросла практически в каждом блоке в 8-10 раз. Хотя при этом суммарное количество событий от источников увеличилось всего в 1,26 раза. Это связано с тем, что события проводят в очереди на обработку больше времени, чем в самих блоках обработки. По сравнению с экспериментом 1, максимальное количество событий в очереди в каждом блоке возросло в 4-5 раз.

Количество событий, которые успевает накапливаться для обработки в блоке агрегации за 0,5 секунды, увеличивается примерно на 20-30%.

Оценим время обработки событий в блоках SIEM-системы в рамках эксперимента 2. Так в блоке сбора и нормализации время обработки увеличивается, при этом его максимальное значение прирастает в 2 раза. То же наблюдается в блоке фильтрации, причем максимальное значение времени обработки увеличивается в 5 раз.

Подобная же картина наблюдается применительно к блоку корреляции, при этом его максимальное значение увеличивается в 6 раз.

Отметим, что общее время обработки увеличилось не настолько, как в отдельных

блоках, а его максимальное значение увеличивается только в 2 раза.

Результаты эксперимента 3

При проведении эксперимента необходимо было игнорировать “лишние” события в блоке сбора и нормализации, так как его вместимость всего 3 тыс. событий. Потери за час работы составляют более 5,5 млн. событий. Определить, являются ли они инцидентами или нет, на данном этапе невозможно. Поэтому из-за таких серьезных потерь можно пропустить серьезную кибератаку на предприятие.

В этом смысле эксперимент 3 – демонстрационный, показывающий, как не нужно проектировать SIEM-систему, чтобы не возникали неоправданные очереди в обслуживании сообщений о событиях и не было пропусков серьезных кибератак на информационную инфраструктуру предприятий.

Эксперимент 3 показал, что загрузка блоков фильтрации и корреляции увеличилась по сравнению с загрузкой в рабочее время в эксперименте 1. При этом время обработки событий в блоке фильтрации увеличилось в 12,5 раз, а в блоке корреляции – в 17,5 раз. Загрузка блока сбора и нормализации в связи с введенными ограничениями достигла 3 тыс. событий. Общее время обработки событий в SIEM-системе увеличилось в 8,3 раза, по сравнению с результатами эксперимента 1 и при максимальной нагрузке самое большое время обработки событий составляет 5,5 секунд.

Обобщенные результаты экспериментов приведены в табл. 1.

Таблица 1

Сравнение характеристик блоков SIEM-системы в проведенных экспериментах

	Эксперимент 1 (рабоч. время)	Эксперимент 1 (нерабоч. время)	Эксперимент 2	Эксперимент 3
Очередь в блоке сбора и нормализации				
Средняя	1,26	0,0006	11,24	2998
Максимальная	30	3	146	3000
Очередь в блоке фильтрации				
Средняя	0,57	0,0003	4,43	21,6
Максимальная	19	2	67	286
Очередь в блоке корреляции				
Средняя	1,14	0,0006	8,72	100,1
Максимальная	19	2	74	299
Загрузка блока агрегации				
Средняя	1149	50,7	1450	1514,9
Максимальная	1314	86	1543	1559

Выводы

1. Имитационная модель центра мониторинга информационной безопасности позволяет решать широкий спектр задач, в частности, задач управления временем

2. Для решения задачи моделирования процессов, связанных с обеспечением информационной безопасности предприятий, хорошо применимы методы дискретно-событийного моделирования. Разработанная дискретно-событийная модель ЦИБП позволяет решать широкий спектр задач, в частности, задач управления, оптимизации, прогнозирования и анализа в сфере информационной безопасности современных предприятий.

3. Дискретно-событийная модель ЦИБП удовлетворяет основным требованиям:

современных трендов в области технологического обеспечения информационной безопасности предприятий и организаций;

по учету наиболее существенных факторов, влияющих на характеристики информационной безопасности предприятий;

по обеспечению баланса между требуемой точностью результатов моделирования и сложностью модели;

универсальности, благодаря которой она может быть легко адаптирована для решения многих задач управления информационной безопасности с учетом дополнительных факторов;

гибкости разработки моделей в современной среде имитационного моделирования, которая позволяет менять значения параметров модели во время ее работы, наблюдать в онлайн-режиме изменения исследуемых процессов.

4. Выбранное в качестве среды имитационного моделирования программное обеспечение отечественного производства Anylogic позволяет проигрывать различные сценарии кибератак на ЦИБП, качественно интерпретировать результатов реализации моделей, проводить различные виды имитационных экспериментов, в том числе – по вариации параметров моделей, анализа их чувствительности, оптимизации ресурсного обеспечения информационной защиты.

5. На основе исследований модели можно готовить обоснованные решения о

обработки сообщений об инцидентах безопасности, оптимизации ресурсного обеспечения информационной безопасности предприятия, ее прогнозирования.

возможности установки SIEM-системы того или иного класса на предприятие, нагрузке на такую систему, об установке дополнительных SIEM-систем или о замене их на более производительные, о комплектовании штата специалистов SOC-центров.

6. Дальнейшим развитием исследования ЦИБП предприятий является уточнение и детализация модели, параметров блоков и сообщений об инцидентах, а также проведение дополнительной серии имитационных экспериментов с различными комбинациями факторов. А именно, более углубленное исследование факторов киберпреступности, дополнительных блоков SIEM-системы более эффективных методов фильтрации, агрегации и корреляции, а также комплексное изучение совместной работы SIEM-систем и SOC-центров.

Список литературы

1. Кибермишени 2019 как тренды 2020 – статистика Solar JSOC. URL: https://www.securitylab.ru/blog/company/solars_eurity/348031.php. (Дата обращения 21.06.2021).

2. Для чего нужна система SIEM и как её внедрить? URL: http://www.tadviser.ru/index.php/Статья:Для_чего_нужна_система_SIEM_и_как_её_внедрить_TADетали (Дата обращения 21.06.2021).

3. Security and Privacy Controls for Federal Information Systems and Organizations/ NIST Special Publication 800-53 Revision 4, April 2013. URL: <http://dx.doi.org/10.6028/NIST.SP.800-53r4> (Дата обращения 21.06.2021).

4. Федеральный закон от 26.07.2017 № 187-ФЗ «О безопасности критической информационной инфраструктуры российской федерации».

5. Постановление Правительства РФ от 8 февраля 2018 г. № 127 «Об утверждении Правил категорирования объектов критической информационной инфраструктуры Российской Федерации, а также перечня показателей критериев значимости объектов критической

информационной инфраструктуры Российской Федерации и их значений».

6. Постановление Правительства РФ от 8 июня 2019 г. № 743 «Об утверждении Правил подготовки и использования ресурсов единой сети электросвязи Российской Федерации для обеспечения функционирования значимых объектов критической информационной инфраструктуры».

7. Приказ Федеральной службы по техническому и экспортному контролю от 6 декабря 2017 г. N 227 «Об утверждении Порядка ведения реестра значимых объектов критической информационной инфраструктуры Российской Федерации».

8. Приказ Федеральной службы по техническому и экспортному контролю от 21 декабря 2017 г. № 235 «Об утверждении Требований к созданию систем безопасности значимых объектов критической информационной инфраструктуры Российской Федерации и обеспечению их функционирования».

9. Приказ Федеральной службы по техническому и экспортному контролю от 11 февраля 2013 г. № 17 «Об утверждении требований о защите информации, не составляющей государственную тайну, содержащейся в государственных информационных системах».

10. Приказ Федеральной службы по техническому и экспортному контролю от 18 февраля 2013 г. № 21 «Об утверждении состава и содержания организационных и технических мер по обеспечению безопасности персональных данных при их обработке в информационных системах персональных данных».

11. Постановление Правительства РФ от 17.02.2018 № 162 «Об утверждении Правил осуществления государственного контроля в области обеспечения безопасности значимых объектов критической информационной инфраструктуры Российской Федерации».

12. Приказ ФСТЭК России от 25.12.2017 № 239 «Об утверждении Требований по обеспечению безопасности значимых объектов критической информационной инфраструктуры Российской Федерации».

13. Приказ ФСТЭК России от 09.08.2018 № 138 «О внесении изменений в требования к обеспечению защиты информации в

автоматизированных системах управления производственными и технологическими процессами на критически важных объектах, потенциально опасных объектах, а также объектах, представляющих повышенную опасность для жизни и здоровья людей и для окружающей природной среды, утвержденные приказом федеральной службы по техническому и экспортному контролю от 14 марта 2014 г. № 31, и в требования по обеспечению безопасности значимых объектов критической информационной инфраструктуры российской федерации, утвержденные приказом Федеральной службы по техническому и экспортному контролю от 25 декабря 2017 г. № 239».

14. Приказ ФСБ России от 24.07.2018 № 366 «О Национальном координационном центре по компьютерным инцидентам».

15. Приказ ФСБ России от 06.05.2019 № 196 «Об утверждении Требований к средствам, предназначенным для обнаружения, предупреждения и ликвидации последствий компьютерных атак и реагирования на компьютерные инциденты».

16. Указ Президента РФ от 15.01.2013 № 31 «О создании государственной системы обнаружения, предупреждения и ликвидации последствий компьютерных атак на информационные ресурсы Российской Федерации».

17. Боев В. Д. Исследование адекватности GPSS World и AnyLogic при моделировании дискретно-событийных процессов: Монография. – СПб.: ВАС, 2011. – 404 с.

18. Минаев В. А., Дворянkin С. В. Моделирование динамики информационно-психологических воздействий на массовое сознание // Вопросы кибербезопасности. 2016. № 5(18). – С. 56-64.

19. Минаев В. А. Простые числа: новый взгляд на закономерности формирования. М.: Издательский дом “Логос Пресс”, 2011. – 80 с.

20. Минаев В.А., Сычев М.П., Вайц Е. В., Грачева Ю. В. Моделирование угроз информационной безопасности с использованием принципов системной динамики // Вопросы радиоэлектроники. 2017. № 6. – С. 75-82.

21. Современные системы имитационного моделирования. URL: https://studme.org/191020/ekonomika/sovremennye_sistemy_imitatsionnogo_modelirovaniya (дата обращения 21.06.2021) habr.com/ru/company/solarsecurity/blog/34463 2/. (Дата обращения 21.06.2021).
22. Блог компании Ростелеком-Солар. SOC for Beginners. Как организовать мониторинг инцидентов и реагирование на атаки в режиме 24x7. URL: <https://unlim.group/upload/iblock/1ab/1ab7647ac3694ca215a00ee6a41069dd.pdf>. (Дата обращения 21.06.2021).
23. MaxPatrol SIEM All-In-One – краткое описание продукта. URL:

Московский университет МВД России им. В.Я. Кикотя
V.Ya. Kikot Moscow University of the Internal Affairs Ministry of Russia

Поступила в редакцию 22.06.2021

Информация об авторах

Минаев Владимир Александрович – д-р техн. наук, профессор, Московский университет МВД России им. В.Я. Кикотя, e-mail: m1va@yandex.ru;

Поликарпов Евгений Сергеевич – канд. техн. наук, доцент, Московский университет МВД России им. В.Я. Кикотя, e-mail: binox@mail.ru

SIMULATION OF INFORMATION SECURITY CENTER FUNCTIONING IN THE CONTEXT OF CYBER ATTACKS REALIZATION

V.A. Minaev, E.S. Polikarpov

The article is devoted to the problem of modeling the functioning of the Enterprise Information Security Center (EISC) in the context of the realization of cyber attacks. The simulation model allows you to solve a wide range of tasks, in particular, the tasks of managing the processing time of security incident reports, optimizing the resource support of enterprise information security, and forecasting it. It is shown that the methods of discrete-event modeling are applicable for solving these problems. The discrete-event model of EISC reflects modern trends in the field of technological support of information security of enterprises and organizations; takes into account the most significant factors that affect the characteristics of information security of enterprises; provides a balance between the required accuracy of modeling results and the complexity of the model; is characterized by versatility, adaptability to solve many problems of information security management, flexibility of model development in the modern environment of simulation modeling. As a simulation environment, Anylogic software of domestic production was chosen, which made it possible to play various scenarios of cyber attacks on the EISC, which helps to qualitatively interpret the results of the implementation of models, to conduct various types of simulation experiments, including the variation of model parameters, the analysis of their sensitivity, and the optimization of the resource provision of information protection. It is concluded that the further development of the study of the EISC of enterprises is the refinement and detailing of the model, the structure of its blocks and the content of messages about computer incidents.

Keywords: cyber attack, enterprise, information security, discrete-event modeling, SIEM-system, SOC-center, simulation.

Submitted 22.06.2021

Information about the authors

Vladimir A. Minaev – Dr. of Engineering, Professor, V.Ya. Kikot Moscow University of the Internal Affairs Ministry of Russia, e-mail: m1va@yandex.ru

Evgeny S. Polikarpov – Cand. Sc (Technical), Professor, V.Ya. Kikot Moscow University of the Internal Affairs Ministry of Russia, e-mail: binox@mail.ru